COMPTIA SECURITY+ SY0-701 DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.2 · Port Security

Mestre CyberSec · **Lesson 3.2 — Port Security** (3:50) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: 802.1X: autentica o USUÁRIO/máquina antes de dar acessoà rede via switch. RADIUS centraliza o AAA. Sem 802.1X, qualquer um conecta e tem acesso. NAC (Network Access Control) = 802.1X + postura (antivirus/patch health).

💡 Key Exam Highlights & Critical Concepts

- 802.1X: autentica ANTES de dar acesso à porta do switch
- RADIUS: o backend central de AAA
- NAC: 802.1X + checagem de saúde (antivirus, patch)

🎯 Exam Tips & Typical CompTIA Scenarios

- 'requires authentication before network access'=802.1X

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.2 — Port Security)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• IEEE 802.1X (802.1X)

IEEE standard for port-based network access control that authenticates a supplicant before granting access to a switch port or wireless network.

⚠️ ***Exam Trap:*** *Se a questão disser 'requires authentication before network access' ou 'port-based access control', a resposta é 802.1X; não confunda com MAC filtering, que apenas filtra endereços.*

• Extensible Authentication Protocol (EAP)

Authentication framework used by 802.1X to support multiple authentication methods such as certificate-based or username/password.

⚠️ ***Exam Trap:*** *EAP é o método de autenticação dentro do 802.1X; não fornece criptografia por si só. EAP-TLS usa certificado, PEAP usa túnel TLS.*

• Remote Authentication Dial-In User Service (RADIUS)

Centralized AAA server protocol commonly used with 802.1X to authenticate, authorize, and account for network access.

⚠️ ***Exam Trap:*** *RADIUS é o backend central de AAA; quando a questão mencionar 'centralized authentication' com 802.1X, pense RADIUS. Não confunda com TACACS+, que é mais usado para administração de dispositivos Cisco.*

• Authentication, Authorization, and Accounting (AAA)

Security framework that verifies identity (authentication), grants permissions (authorization), and logs activity (accounting).

⚠️ ***Exam Trap:*** *RADIUS centraliza AAA. Não confunda autenticação (quem é) com autorização (o que pode fazer) e accounting (registro/auditoria).*

• Network Access Control (NAC)

Security approach that combines 802.1X authentication with posture assessment to ensure devices meet compliance before network access.

⚠️ ***Exam Trap:*** *NAC = 802.1X + health/posture check. Se a questão exigir checar antivírus ou patches antes de permitir acesso, a resposta é NAC.*

• Posture Assessment (N/A)

Health check performed by NAC to verify endpoint compliance such as antivirus status, patch level, and firewall settings before granting access.

⚠️ ***Exam Trap:*** *Gatilho: 'antivirus/patch health' ou 'compliance check' antes do acesso = posture assessment, parte do NAC.*

• 802.1X Roles (Supplicant, Authenticator, Authentication Server)

In 802.1X, the supplicant is the client requesting access, the authenticator is the switch/AP controlling the port, and the authentication server is typically RADIUS validating credentials.

⚠️ ***Exam Trap:*** *Diferencie: supplicant = cliente; authenticator = switch; authentication server = RADIUS. O switch não valida credenciais; ele repassa ao RADIUS.*

• Port Security (MAC Address Limiting) (N/A)

Switch feature that restricts which MAC addresses can use a port, often via sticky MAC, MAC limits, and violation modes (shutdown, restrict, protect).

⚠️ ***Exam Trap:*** *Port security com MAC filtering não autentica usuário; apenas limita MACs. 802.1X autentica antes do acesso. Violation modes: shutdown derruba a porta, restrict descarta e gera log, protect descarta silenciosamente.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Switch Port Security: MAC Filtering and Sticky MAC

🏠 **Real-World Analogy:** Imagine a smart office wall power outlet: when you first plug in your corporate laptop, the socket dynamically records your device's unique physical serial ID (Sticky MAC) and commits it to memory. If an unauthorized visitor unplugs your laptop and connects their rogue machine, the socket immediately cuts power completely (Shutdown), locks down, and signals the front desk.

🔍 **Root Cause & Background:** Attackers with physical office access can disconnect VoIP phones or printers to attach malicious laptops directly into corporate VLANs. Switch Port Security limits allowable MAC addresses per interface and enforces penalty modes (Shutdown, Restrict, Protect).

🛡️ **GRC Auditor Perspective:** Audit access switch running configurations; mandate that edge access ports enable Port Security with 'violation shutdown' (err-disable) and ensure all unused switch ports are administratively shut down.

⚠️ **How CompTIA Tests This:** Trigger: 'dynamically learns the connected device MAC address and saves it into the running configuration, disabling the port if a different MAC is connected'. Answer: Port Security Sticky MAC.

📌 Network Access Control (NAC): IEEE 802.1X Standard and EAP-TLS

🏠 **Real-World Analogy:** Think of an airlock turnstile in a high-security defense compound: plugging in an ethernet cable grants zero network communication. The switch operates as the gate guard (Authenticator), demanding that your computer (Supplicant) present a cryptographically verified corporate passport (Client Digital Certificate). The guard verifies this badge with the central directory vault (RADIUS Server). Upon approval, the gate opens; otherwise, the device is isolated in a sterile quarantine VLAN.

🔍 **Root Cause & Background:** MAC filtering is trivially bypassed via MAC spoofing. IEEE 802.1X provides port-based Network Access Control (PNAC) enforcing strong cryptographic authentication (via EAP-TLS certificates) between Supplicant, Authenticator, and RADIUS backend before enabling frame transmission.

🛡️ **GRC Auditor Perspective:** Audit enterprise 802.1X PKI rollouts; verify that EAP-TLS is enforced using machine certificates stored securely within TPM hardware chips, eliminating credential theft and password brute-force.

⚠️ **How CompTIA Tests This:** Trigger: 'port-based authentication framework comprising a supplicant, an authenticator, and a central RADIUS authentication server'. Answer: IEEE 802.1X. If 'strongest authentication method using mutual digital certificates' -> EAP-TLS.

📌 Loop Prevention and Topology Protection: BPDU Guard

🏠 **Real-World Analogy:** Imagine a municipal traffic grid with smart roundabouts (Spanning Tree Protocol) preventing endless circular traffic jams that paralyze a metropolis. BPDU Guard is a sensor guarding designated bicycle lanes: if a rogue driver plugs an unauthorized portable traffic-light controller (a rogue switch sending BPDU packets) into that path, the lane barrier slams shut instantly, preventing a systemic traffic loop blackout.

🔍 **Root Cause & Background:** Employees connecting rogue desktop switches or attackers transmitting malicious BPDU packets to hijack the Spanning Tree Root Bridge position induce crippling Layer 2 broadcast storms. BPDU Guard shuts down access-configured edge ports the moment any BPDU frame is received.

🛡️ **GRC Auditor Perspective:** Validate switch port hardening policies; ensure BPDU Guard is globally enabled on all PortFast access interfaces, preventing rogue bridging devices from disrupting the Spanning Tree topology.

⚠️ **How CompTIA Tests This:** Trigger: 'feature that protects the network by disabling a switch port if an unauthorized switch or BPDU frame is detected on an access port'. Answer: BPDU Guard.

📌 Rogue Server Defense: DHCP Snooping

🏠 **Real-World Analogy:** Imagine a municipal passport issuance desk: only window #1 houses the authorized government registrar. A fraudster sets up a folding chair in the waiting hall and starts issuing forged passports listing his personal PO Box as the government tax office (Rogue DHCP). DHCP Snooping designates window #1 as the sole 'Trusted Port': if unauthorized packets (DHCP Offers) emerge from waiting area ports, the switch discards them immediately.

🔍 **Root Cause & Background:** Rogue DHCP servers deceive endpoints into accepting spoofed default gateway and DNS assignments, facilitating passive on-path eavesdropping. DHCP Snooping classifies switch interfaces into Trusted (legitimate DHCP uplinks) and Untrusted (user endpoints), dropping rogue DHCP Offer/ACK frames.

🛡️ **GRC Auditor Perspective:** Audit switch configurations to verify DHCP Snooping is enforced on all user VLANs; confirm only designated server uplinks are configured as 'trusted', and ensure the resulting snooping database feeds Dynamic ARP Inspection (DAI).

⚠️ **How CompTIA Tests This:** Trigger: 'switch security mechanism that blocks rogue DHCP servers by categorizing ports into trusted and untrusted interfaces'. Answer: DHCP Snooping.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Switch port registers connected MAC address into memory and shuts down interface if an unrecognized MAC is plugged in	**Port Security (Sticky MAC)**
Port-based Network Access Control framework mandating digital certificate authentication via RADIUS before unlocking traffic	**802.1X with EAP-TLS**
Defensive switch setting that puts an access interface into error-disabled state upon receiving rogue STP BPDU frames	**BPDU Guard**
Security feature dropping unauthorized DHCP server responses on untrusted ports to prevent rogue gateway spoofing	**DHCP Snooping**
Security feature validating ARP packets against the DHCP snooping database to eradicate ARP poisoning attacks	**Dynamic ARP Inspection (DAI)**
Layer 2 logical segmentation partitioning a physical switch into distinct, isolated broadcast domains	**VLAN (Virtual Local Area Network)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A regional hospital has enabled 802.1X on all wired access switches. When a nurse connects a laptop to a wall jack, the port stays blocked until the laptop presents credentials, and the switch then relays that exchange to the RADIUS server before opening the port. Which 802.1X role is the switch performing in this design?

A) Supplicant

B) Authenticator

C) Authentication server

D) Certificate authority

QUESTION 2 · EXAM SCENARIO

A company operates 300 access switches across 12 sites and wants a single authoritative store of user credentials, consistent access policy, and centralized logs of every authentication. Which solution best meets these requirements?

A) Creating identical local user accounts in the configuration of every switch

B) Deploying a RADIUS server that all switches query for AAA services

C) Enabling sticky MAC address learning on every access port

D) Placing each department in its own VLAN with a dedicated subnet

QUESTION 3 · EXAM SCENARIO

A contractor's laptop authenticates successfully to the corporate LAN, but the NAC solution detects that the operating system is missing critical patches and that the antivirus signatures are three months old. The laptop is placed on a VLAN that can reach only the patch and antivirus update servers. Which NAC capability produced this outcome?

A) RADIUS accounting

B) Port security with sticky MAC addresses

C) Posture (host health) assessment

D) EAP-TLS mutual authentication

QUESTION 4 · EXAM SCENARIO

During a walkthrough, a technician discovers that someone plugged an unmanaged mini-switch into a conference room wall jack and connected four personal laptops through it, all of which obtained corporate IP addresses. Which control would most directly prevent this on the access layer?

A) Enabling EAP-TLS in the supplicant of each corporate endpoint

B) Configuring port security with a maximum MAC address count on access ports

C) Deploying RADIUS accounting on all access-layer switches

D) Assigning all conference room wall jacks to the guest VLAN

QUESTION 5 · EXAM SCENARIO

A financial institution requires that both the user's device and the authentication server prove their identities with X.509 digital certificates, and that no password ever traverse the network during authentication. Which EAP method should the security team select?

A) EAP-TLS

B) EAP-MD5

C) PEAP

D) LEAP

QUESTION 6 · EXAM SCENARIO

After a user successfully completes 802.1X authentication, the RADIUS server returns attributes that place the session in the Accounting VLAN and push an access control list permitting only the finance application. Which AAA function do these returned attributes implement?

A) Authentication

B) Accounting

C) Authorization

D) Auditing

QUESTION 7 · EXAM SCENARIO

A network engineer is troubleshooting a wired 802.1X deployment. The client's supplicant and the switch exchange EAP frames before the switch forwards anything to the RADIUS server. Which protocol carries those EAP frames across the link between the supplicant and the authenticator?

A) EAPOL

B) RADIUS

C) TACACS+

D) LDAP

QUESTION 8 · EXAM SCENARIO

An attacker copies the MAC address of an authorized workstation onto a rogue laptop and connects to an access port that has sticky MAC address learning enabled. The switch accepts the connection and the attacker reaches internal resources. Which control would best prevent this attack in the future?

A) Raising the maximum MAC address limit on the access ports

B) Enabling sticky MAC address learning on additional ports

C) Configuring DHCP snooping on the access switches

D) Deploying 802.1X with certificate-based authentication on the access ports

QUESTION 9 · EXAM SCENARIO

A regulated organization must show auditors a record of every user who connected to the wired network, the specific switch and port used, and the start and end time of each session. Which AAA component supplies this evidence?

A) Posture assessment

B) Accounting

C) Authentication

D) Authorization

QUESTION 10 · EXAM SCENARIO

A manufacturing plant has legacy IP cameras and label printers that have no 802.1X supplicant and cannot be modified. The security team still wants these devices authenticated and placed in a restricted VLAN instead of sitting on wide-open ports. Which approach is most appropriate?

A) Disabling 802.1X on all access ports in the plant

B) Configuring MAC Authentication Bypass on the switch ports used by those devices

C) Installing an EAP-TLS client certificate into the devices' firmware

D) Setting the port security maximum MAC address count to zero

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Authenticator

In 802.1X the switch port acts as the authenticator. It holds the port in an unauthorized state (only EAPOL traffic permitted) until the supplicant — the client software on the endpoint — proves its identity, then re-encapsulates the EAP exchange in RADIUS packets toward the authentication server and opens or restricts the port based on the decision returned. The authenticator relays credentials; it does not validate them itself, and it is not the endpoint's supplicant nor a certificate authority.

Question 2: Option B — Deploying a RADIUS server that all switches query for AAA services

RADIUS centralizes Authentication, Authorization, and Accounting for 802.1X deployments. All switches (authenticators) forward credential exchanges to one authoritative server, so policy is applied consistently and accounting records land in one auditable repository. Local switch accounts do not scale, cannot be centrally audited, and do not provide per-user 802.1X authentication; sticky MAC and VLAN segmentation solve different problems.

Question 3: Option C — Posture (host health) assessment

Posture assessment is the NAC function that inspects the endpoint's health state — patch level, antivirus/EDR currency, firewall status, disk encryption — after the identity is verified, and then enforces the result, typically by assigning non-compliant devices to a remediation or quarantine VLAN with restricted reachability. Accounting only records sessions, port security limits MAC addresses, and EAP-TLS is the authentication method used to verify identity, not device health.

Question 4: Option B — Configuring port security with a maximum MAC address count on access ports

Port security restricts how many distinct source MAC addresses may appear on a port. When the configured maximum is exceeded the switch can shut the port down or drop the excess addresses, which defeats the daisy-chained mini-switch scenario. EAP-TLS only authenticates corporate endpoints that have a supplicant, accounting merely records activity, and moving jacks to a guest VLAN still leaves the ports open to unauthorized devices.

Question 5: Option A — EAP-TLS

EAP-TLS requires certificates on both the client and the server, delivering mutual authentication and a strong key exchange without transmitting passwords. PEAP and EAP-TTLS use only a server-side certificate and then tunnel an inner authentication method that is usually password-based; EAP-MD5 provides no mutual authentication, no key derivation, and is considered obsolete; LEAP is a legacy Cisco-proprietary method with known weaknesses.

Question 6: Option C — Authorization

Authorization determines what an authenticated principal is permitted to do. VLAN assignment, downloadable ACLs, session timeouts, and role attributes returned by RADIUS after the identity check are all authorization decisions. Authentication establishes identity, accounting records session activity for later review, and auditing is the separate review of those records rather than a runtime AAA function.

Question 7: Option A — EAPOL

EAPOL (EAP over LAN) is the Layer 2 encapsulation defined by IEEE 802.1X for the supplicant-to-authenticator segment. The authenticator terminates EAPOL, then re-packages the EAP payload inside RADIUS packets for the authentication server. RADIUS, TACACS+, and LDAP operate on the server side of the exchange and are not the carrier used on the endpoint-to-switch link.

Question 8: Option D — Deploying 802.1X with certificate-based authentication on the access ports

Certificate-based 802.1X ties port access to an identity the attacker cannot replicate by editing a MAC address, since the rogue device cannot complete the EAP-TLS exchange without a valid client certificate. Sticky MAC learning only pins the first MAC observed on the port; because the attacker presents that same MAC, no violation is triggered. Raising the MAC limit weakens policy and DHCP snooping only defends against rogue DHCP servers and forged DHCP bindings.

Question 9: Option B — Accounting

Accounting is the AAA component that logs session activity: who connected, from where, to which port or device, when the session started and stopped, and sometimes how much data was transferred. These records feed compliance reporting and forensic investigations. Authentication and authorization are real-time decisions made during the connection attempt, while posture assessment evaluates endpoint health.

Question 10: Option B — Configuring MAC Authentication Bypass on the switch ports used by those devices

MAC Authentication Bypass lets the switch submit the endpoint's MAC address to the RADIUS server as the credential for devices that cannot run a supplicant, and RADIUS authorization attributes then place the device in the correct

restricted VLAN. It is weaker than certificate-based 802.1X, so it should be combined with port security, MAC allow-lists, and segmentation. Disabling 802.1X leaves ports open, the firmware cannot accept EAP-TLS, and a MAC limit of zero would block the device entirely.